CYBER SECURITY DAY

SPEAKER

Rocco Sicilia



L'ASIMMETRIA DELL'ATTACCO PERCHÉ NESSUNA DIFESA È MAI L'ULTIMO CAPITOLO.

CYBER LEADER PARTNER

FORFIRM
THE FUTURE, DELIVERED!

CYBER PRO PARTNER

lastminutefoundation

AppScanner.ai

CYBER SUPPORT PARTNER

ail

PARTNER TECNICO

INFINITY

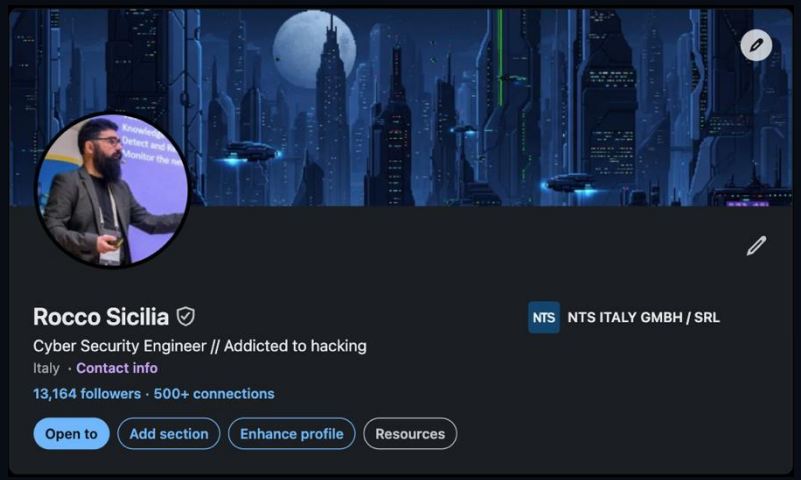


L’asimmetria dell’attacco

Perché nessuna difesa è mai l'ultimo capitolo.

howami

- Security Engineer @NTS
- Addicted to hacking



L’eterno scontro

50+

ANNI DI SFIDE CONTINUE

Nel mondo dell’info security si è spesso fatto riferimento al gioco “guardie e ladri” per spiegare l’evoluzione del settore.

Oggi ripercorriamo una parte di storia dello sviluppo delle minacce informatiche, osservando come le evoluzioni degli attaccanti costringano i difensori a reinventarsi, e viceversa.

IM THE CREEPER, CATCH ME IF YOU CAN!

Mossa #1: L’era dell’innocenza

STRATEGIA ATTACCANTE

I primi malware “fisici”

- **Mezzo Fisico:** Diffusione lenta tramite Floppy Disk e rumore localizzato (es. Creeper, Michelangelo).
- **Scrittura sul Disco:** Il codice malevolo era statico, grezzo ma incredibilmente efficace su sistemi privi di protezioni.
- **Obiettivo Unico:** Dimostrare la fattibilità dell'infezione o provocare danni evidenti e visibili.



Risposta #1: scansione e riconoscimento



La Firma (Hash)

Ogni file malevolo ha un'impronta digitale unica. Registrando l'hash, l'antivirus lo identifica all'istante.



Scansione Disco

Gli antivirus tradizionali ispezionano periodicamente i file presenti sul disco, confrontandoli con un database noto.



Blocco Reattivo

Trovata la corrispondenza con l'impronta criminale, l'accesso viene revocato e il file viene messo in quarantena.

Mossa #2: mutazioni

POLIMORFISMO

Cambiare senza cambiare

Il malware capisce che la firma lo sta uccidendo. Introduce motori polimorfi: il corpo del codice cambia aspetto (l'hash si modifica a ogni infezione) ma esegue le medesime azioni logiche una volta decifrato in memoria.

METAMORFISMO

Riscrizione totale

I virus iniziano a mutare la loro stessa struttura interna a ogni iterazione, invertendo istruzioni e registri. Il database delle firme statiche dei difensori è ufficialmente entrato in una crisi profonda.

Risposta #2: L’era del sospetto

EVOLUZIONE DIFENSORE

Guardare le azioni, non le impronte

Dal momento che i malwsre mutano, la difesa smette di fidarsi dei soli hash statici e introduce l'euristica dinamica.

Euristica e Sandbox: Il file sconosciuto viene fatto detonare all'interno di una gabbia isolata (Sandbox). Se prova ad agire come un ladro, viene prontamente neutralizzato.



Mossa #3: diventare stealth

VIVERE SULLA TERRA DEL NEMICO

Il Malware “senza file”

- **Nessun File su Disco:** Se la guardia controlla i file memorizzati... l'attaccante smette di scriverli. Il codice vive solo all'interno della RAM.
- **Living off the Land:** Sfruttamento di strumenti integrati e legittimi nel sistema operativo (es. PowerShell, WMI).
- **Prossimità Fisica:** Iniezione dei payload direttamente in memoria, invisibile agli antivirus tradizionali.

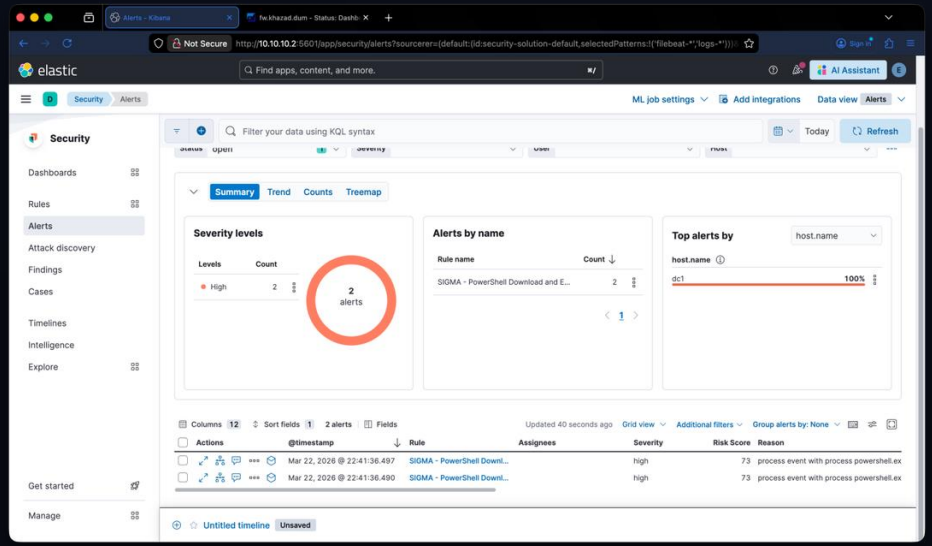


Risposta #3: sorveglianza totale



EVOLUZIONE DIFENSORE

- visibilità
- tecnologie affidabili
- logiche di correlazione



Mossa #4: volare sotto i radar

API UNHOOKING

Gli EDR si interpongono (hooking) tra il malware e le funzioni del sistema operativo. L'attaccante moderno scavalca la "spia" ricaricando in memoria una copia intatta di librerie di sistema come ntdll.dll, eliminando di fatto i controlli dell'EDR.

DIRECT SYSCALLS

Saltare interamente le API controllate dall'EDR in modalità utente (User Mode). L'attaccante esegue chiamate di sistema (Syscalls) dirette al Kernel per allocare memoria o creare processi senza che la guardia possa ascoltare.

Risposta #4: integrazione profonda

LA DIFESA OGGI

Callback e Protezione Kernel

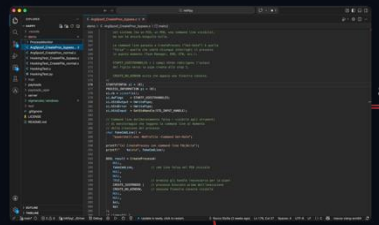
I difensori non si arrendono. Poiché l'utente non è più sicuro, gli EDR scendono nel cuore del sistema operativo.

Kernel Telemetry: Utilizzo dei driver del kernel (Kernel Callbacks, ETW-Ti) per intercettare gli attacchi alla sorgente. Nessun unhooking a livello utente può fermare il monitoraggio diretto a livello di kernel.



Mossa #5: “questi non sono i droidi che state cercando”





CreateProcess
(suspended)

spoofing

Kernel

EPROCESS
PPID registrato

PEB pointer
user space

EDR
Kernel Callback

PsSetCreateProcessNotifyRoutineEx // notifica EDR

CommandLine
Tampering

PEB (user space)

RTL_USER_PROCESS_PARAMETERS
CommandLine - ImagePathName - Environment

Area accessibile in RW

ResumeThread()



Offense informs Defense ---- Defense inspires Offense

-- Grazie --

